

NEW CRITICAL VULNERABILITY ADVISORY: CVE-2026-83627

Summary

CVE-2026-83627 is a newly disclosed Critical vulnerability. It is not yet on CISA's actively-exploited list; treat it as proactive patching before it is weaponised. The Hummingbird – Speed Optimization, Caching, Minify, Compress & CDN plugin for WordPress is vulnerable to Remote Code Execution in all versions up to, and including, 3.21.0 via the `log_msg()` function in `core/modules/class-page-cache.php`. The page-cache debug log is written to `wp-content/wphb-logs/page-caching-log.php`, a directly web-accessible PHP file that is supposed to be protected by a leading " header. That header is guarded by `class_exists('Filesystem')`, which can never match because `class_exists()` resolves string arguments in the global namespace while the class is `Hummingbird\Core\Filesystem`; when the log is created during a front-end request the header is therefore omitted entirely. `get_cookies()` then writes the raw name of any cookie matching the `wphb_cache_` prefix into that file without sanitization. This makes it possible for unauthenticated attackers to write arbitrary PHP into the log file with a single anonymous request and execute it by requesting the file directly, resulting in full remote code execution. Exploitation requires the site administrator to have enabled Page Caching with the Debug Log option (non-default), and the log file to be created during a front-end request — a state reached by the plugin's own 'Clear logs' action, any cache flush, or unattended via the plugin's daily log-rotation cron, which can strip the protective header from an existing log file.

What we know

- **CVE:** CVE-2026-83627
- **Status:** Newly disclosed, not yet known-exploited (not on CISA KEV)
- **Severity:** CVSS 9.8 Critical, Network-exploitable, no privileges required, no user interaction (CVSS:3.1/AV:N/AC:L/PR:N/UI:N/S:U/C:H/I:H/A:H)
- **Exploitation likelihood (EPSS):** 1%

Recommended action

Patch as a fix becomes available, prioritised by the exposure and EPSS above. Until then, restrict network access to the affected service now (segment it, put it behind a VPN, or take it offline) until you can patch. This does not yet trigger CRA 24-hour reporting, which requires active exploitation, but patching ahead of exploitation is the whole point.

Sources: NIST NVD. Public data; an advisory of a newly disclosed vulnerability, not an incident report. Verify applicability to your estate before acting.